Travaux pratiques – Extraire un fichier exécutable d'une capture PCAP

Objectifs

Partie 1: Analyser les journaux précapturés et les captures de trafic

Partie 2: Extraire des fichiers téléchargés à partir de captures de paquets

Contexte/scénario

S'il est essentiel de consulter les fichiers journaux, il l'est également de comprendre comment sont effectuées les transactions réseau au niveau des paquets.

Au cours de ces travaux pratiques, vous allez analyser le trafic dans un fichier pcap précédemment capturé et extraire un fichier exécutable à partir de ce fichier.

Ressources requises

- Poste de travail CyberOps VM

Instructions

Partie 1 : Analyser les journaux précapturés et les captures de trafic

Dans la partie 2, vous allez utiliser le fichier **nimda.download.pcap**. Capturé lors d'un précédent TP, le fichier **nimda.download.pcap** contient les paquets liés au téléchargement du malware Nimda. Si vous avez créé le fichier dans le TP précédent et que vous n'avez pas réimporté votre poste de travail virtuel CyberOps, votre version du fichier se trouve dans le répertoire /home/analyst directory. Toutefois, une copie de ce fichier est également stockée sur le **poste de travail virtuel CyberOps**, dans le répertoire **/home/analyst/lab.support.files/pcaps** vous pouvez donc réaliser ce TP. Dans un souci de cohérence, ce TP utilisera la version stockée dans le répertoire **pcaps**.

Si **tcpdump** permet d'analyser les fichiers capturés, l'interface graphique de **Wireshark** simplifie encore davantage l'opération. Il est également important de préciser que **tcpdump** et **Wireshark** partagent le même format de fichier pour les captures de paquets. Ainsi, les fichiers PCAP créés par l'un des outils peuvent être ouverts sur l'autre.

a. Définissez le répertoire sur le dossier **lab.support.files/pcaps** et générez une liste des fichiers à l'aide de la commande **ls -l**.

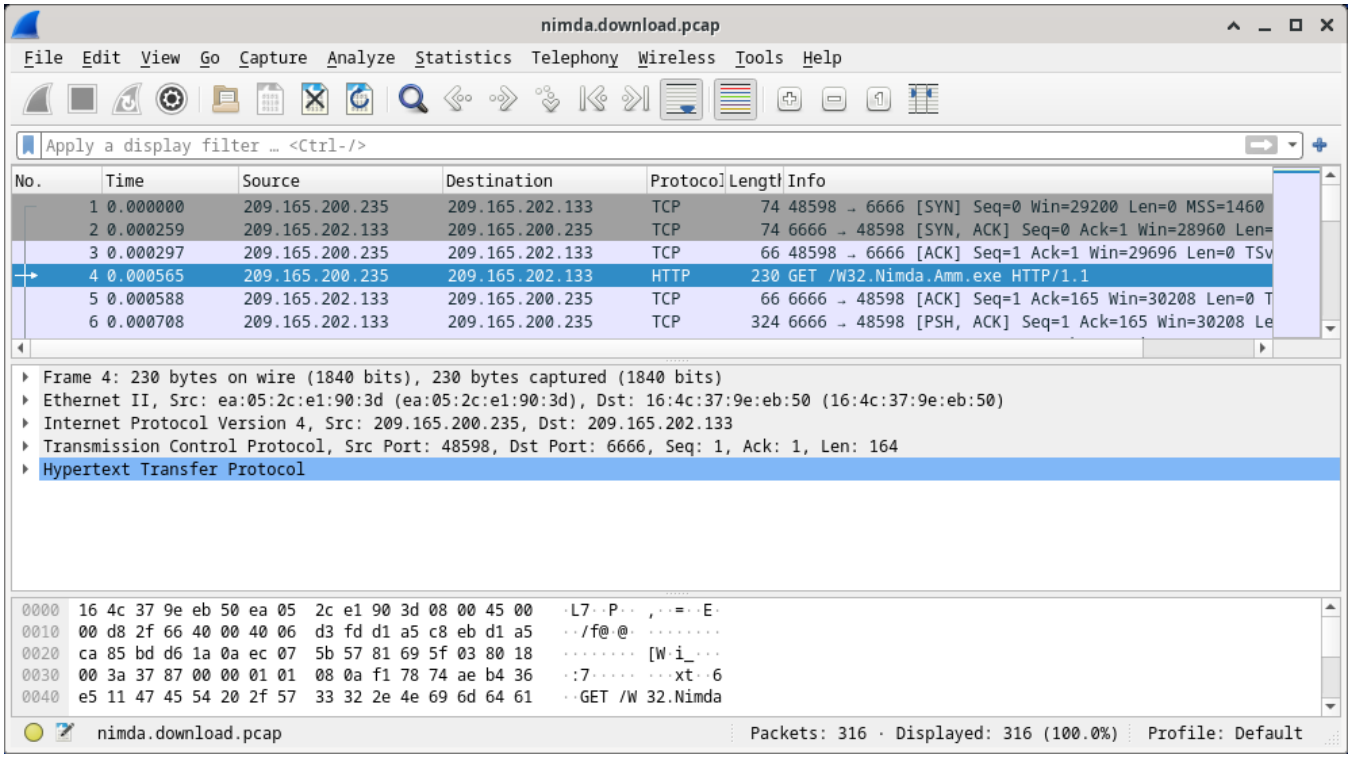
© 2017 - aa Cisco et/ou ses filiales. Tous droits réservés. Document public de Cisco

```
[analyst@secOps ~]$ cd lab.support.files/pcaps
[analyst@secOps pcaps]$ ls -l
total 7460
-rw-r--r-- 1 analyst analyst 3510551 Aug 7 15:25 lab_prep.pcap
-rw-r--r-- 1 analyst analyst 371462 Jun 22 10:47 nimda.download.pcap
-rw-r--r-- 1 analyst analyst 3750153 May 25 11:10 wannacry_download_pcap.pcap
[analyst@secOps pcaps]$
```

b. Exécutez la commande ci-dessous pour ouvrir le fichier **nimda.download.pcap** dans Wireshark.

```
[analyst@secOps pcaps]$ wireshark nimda.download.pcap &
```

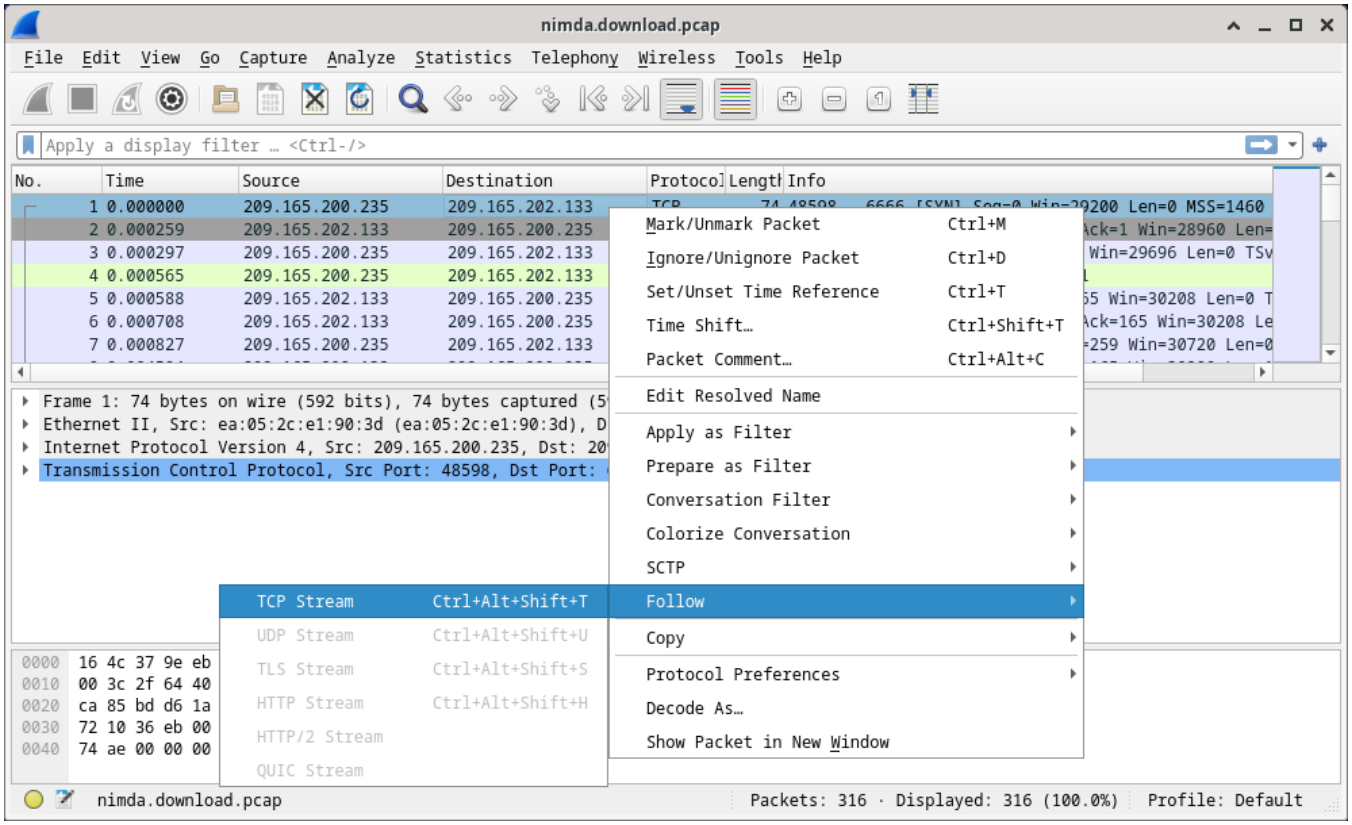
c. Le fichier **nimda.download.pcap** contient la capture de paquets associée au téléchargement du malware dans un précédent TP. Le fichier **pcap** contient tous les paquets envoyés et reçus lorsque **tcpdump** était en cours d'exécution. Sélectionnez le quatrième paquet de la capture et développez le protocole HTTP comme illustré ci-dessous.



d. Les trois premiers paquets représentent la connexion TCP. Le quatrième paquet illustre la demande d'accès pour le fichier de malware. Cela confirme ce que l'on savait déjà, à savoir que la demande a été envoyée via le protocole HTTP sous la forme d'une requête GET.

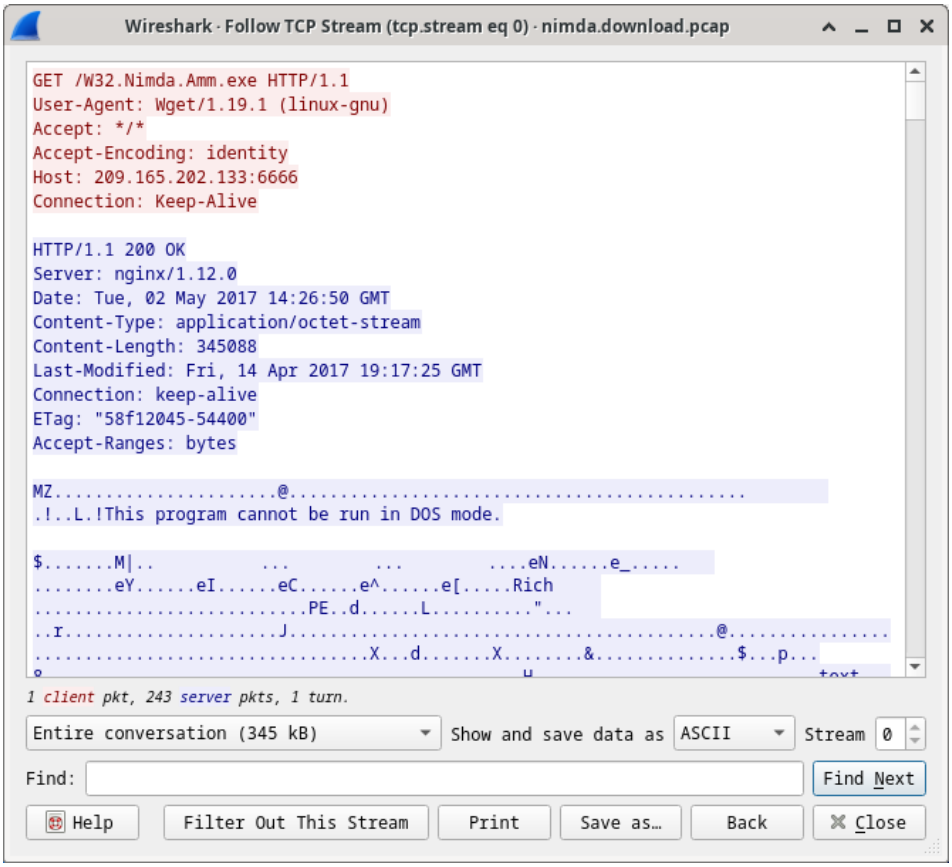
© 2017 - aa Cisco et/ou ses filiales. Tous droits réservés. Document public de Cisco

e. Comme HTTP s'exécute via TCP, vous pouvez utiliser la fonctionnalité **Follow TCP Stream** de **Wireshark** pour reconstruire la transaction TCP. Sélectionnez le premier paquet TCP de la capture qui est un paquet SYN. Cliquez avec le bouton droit et sélectionnez **Follow** > **TCP Stream**.



© 2017 - aa Cisco et/ou ses filiales. Tous droits réservés. Document public de Cisco

f. Wireshark affiche une autre fenêtre qui contient des informations détaillées sur le flux TCP sélectionné complet.



À quoi correspondent tous les symboles qui s'affichent dans la fenêtre **Follow TCP Stream** ? S'agit-il d'interférences ? De données ? Expliquez votre réponse.

On distingue quelques mots lisibles entre les symboles. Pourquoi sont-ils là ?

Question du défi : Même s'il porte le nom **W32.Nimda.Amm.exe**, cet exécutable n'est pas le ver que nous connaissons tous. Pour des raisons de sécurité, il s'agit d'un autre fichier exécutable qui a été rebaptisé **W32.Nimda.Amm.exe**. En utilisant les fragments de mots apparaissant dans la fenêtre Follow TCP Stream de **Wireshark**, pouvez-vous dire de quel exécutable il s'agit en réalité ?

g. Cliquez sur **Close** dans la fenêtre Follow TCP Stream pour revenir au fichier Wireshark nimda.download.pcap.

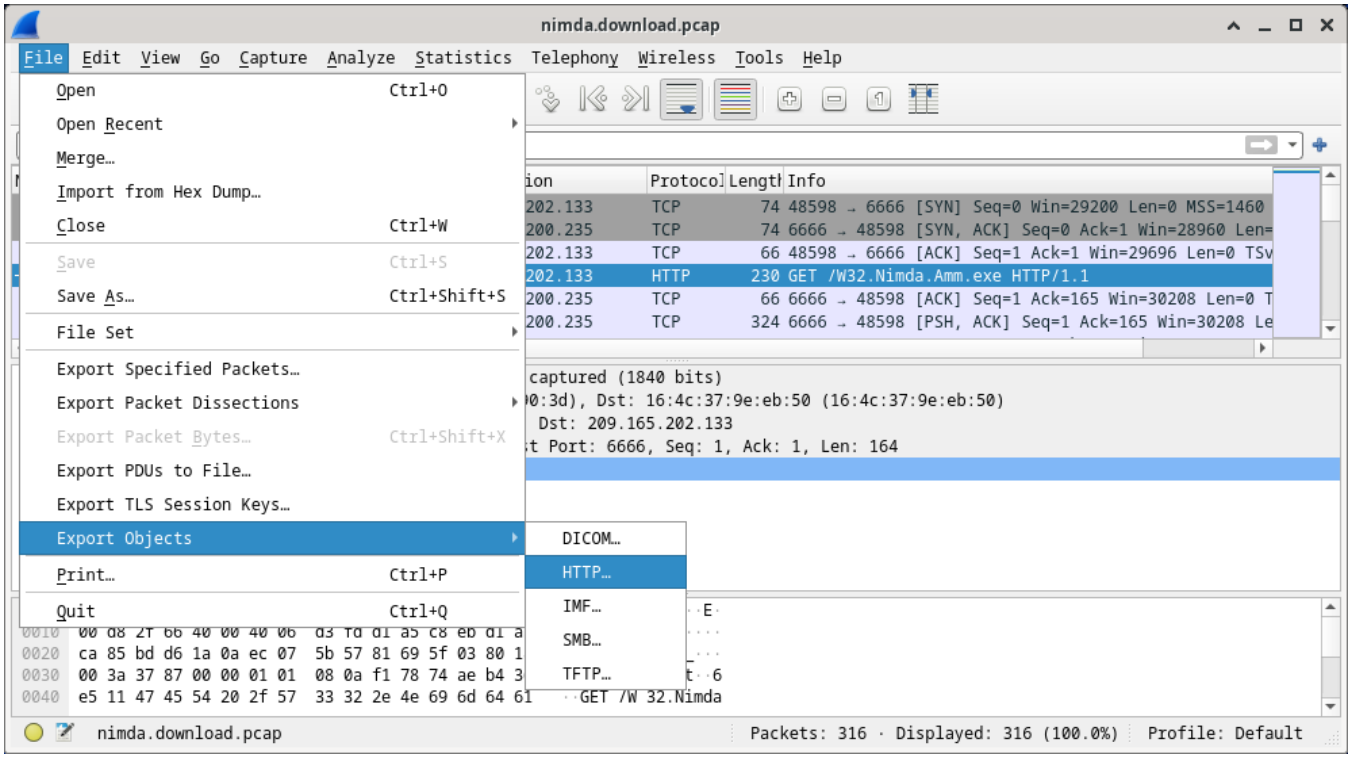
© 2017 - aa Cisco et/ou ses filiales. Tous droits réservés. Document public de Cisco

Partie 2 : Extraire des fichiers téléchargés à partir de captures de paquets PCAP

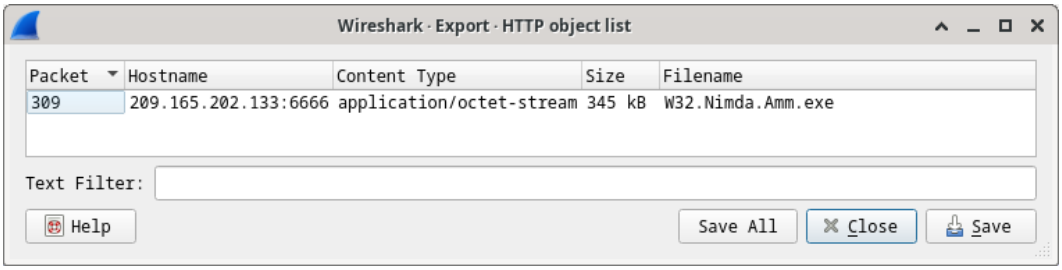
Étant donné que les fichiers de capture contiennent tous les paquets liés au trafic, vous pouvez utiliser la capture de paquets d'un téléchargement pour récupérer un fichier téléchargé précédemment. Suivez les étapes ci-dessous pour récupérer le malware Nimda à l'aide de **Wireshark**.

a. Dans le quatrième paquet du fichier **nimda.download.pcap**, vous pouvez voir que la requête **HTTP GET** a été envoyée de **209.165.200.235** vers **209.165.202.133**. La colonne Info indique également qu'il s'agit en réalité de la requête GET émise pour le fichier.

b. Sélectionnez le paquet de la requête GET, puis accédez à **File > Export Objects > HTTP** à partir du menu de **Wireshark**.



c. Wireshark affichera tous les objets HTTP présents dans le flux TCP qui contient la requête GET. Dans ce cas, seul le fichier **W32.Nimda.Amm.exe** apparaît dans la capture. Le fichier s'affichera au bout de quelques secondes.



Pourquoi la capture contient-elle uniquement le fichier **W32.Nimda.Amm.exe** ?

d. Dans la fenêtre **HTTP object list**, sélectionnez le fichier **W32.Nimda.Amm.exe**, puis cliquez sur **Save As** au bas de l'écran.

e. Cliquez sur la flèche de gauche jusqu'à ce que le bouton **Home** apparaisse. Cliquez sur Home, puis sélectionnez le dossier **analyst** (et non l'onglet analyst). Enregistrez le fichier à cet emplacement.

f. Revenez à la fenêtre du terminal pour vérifier que le fichier a bien été enregistré. Définissez le répertoire sur le dossier **/home/analyst** et générez une liste des fichiers du dossier à l'aide de la commande **ls -l**.

```
[analyst@secOps pcaps]$ cd /home/analyst
[analyst@secOps ~]$ ls -l
total 364
drwxr-xr-x 2 analyst analyst 4096 Sep 26 2014 Desktop
drwx------ 3 analyst analyst 4096 May 25 11:16 Downloads
drwxr-xr-x 2 analyst analyst 4096 May 22 08:39 extra
drwxr-xr-x 8 analyst analyst 4096 Jun 22 11:38 lab.support.files
drwxr-xr-x 2 analyst analyst 4096 Mar 3 15:56 second_drive
-rw-r--r-- 1 analyst analyst 345088 Jun 22 15:12 W32.Nimda.Amm.exe
[analyst@secOps ~]$
```

Le fichier a-t-il été enregistré ?

g. La commande **file** vous donne des informations sur le type de fichier. Utilisez la commande file pour en savoir plus sur le malware, comme illustré ci-dessous :

```
[analyst@secOps ~]$ file W32.Nimda.Amm.exe
W32.Nimda.Amm.exe: PE32+ executable (console) x86-64, for MS Windows
[analyst@secOps ~]$
```

Comme indiqué ci-dessus, **W32.Nimda.Amm.exe** est effectivement un fichier exécutable Windows.

Que pourrait maintenant faire un analyste en sécurité chargé d'analyser le malware ?

© 2017 - aa Cisco et/ou ses filiales. Tous droits réservés. Document public de Cisco